

1. Introduction

In today's rapidly evolving threat landscape, vulnerability management is a critical process for maintaining a strong security posture within any organization. This module offered an in-depth exploration of vulnerability management, emphasizing the importance of identifying and mitigating weaknesses in both internal and external networks. As a cybersecurity student, I found this module to be particularly valuable in bridging theoretical concepts with practical, hands-on skills. Key areas of focus included the distinction between penetration testing and vulnerability assessments, understanding vulnerability scoring systems, and effectively using industry-standard tools such as Nessus and OpenVAS. Through this learning experience, I was able to deepen my knowledge of risk assessment, regulatory compliance, and how vulnerability scanning fits into a larger information security strategy.

2. Module Sections

The image shows a Kali Linux desktop environment with a web browser open to a vulnerability assessment interface. The browser's address bar shows the URL `https://academy.hackthebox.com`. The page has a dark theme and contains several sections:

- Questions:** A section with three questions related to a vulnerability scan. The first question asks for the name of an accessible SMB share, with the answer `wsus` entered. The second question asks for the target of the scan, and the third asks for the plugin ID of the highest criticality vulnerability. Each question has a "Submit" button.
- Success:** A green notification box in the top right corner stating "Success: Congratulations! You earned 1 cubes!".
- Download VPN Connection File:** A button in the top right corner.

Below the browser window, the Nessus web console is visible. The top navigation bar includes "Scans", "Settings", "Configure", "Audit Trail", "Launch", "Report", and "Export". The left sidebar shows "FOLDERS" (My Scans, All Scans, Trash) and "RESOURCES" (Policies, Plugin Rules). The main content area displays a scan titled "Microsoft Windows SMB Shares Access" with a "Vulnerabilities" tab selected. The scan results show a list of shares accessible as administrator:

```
The following shares can be accessed as administrator :
- wsus - (readable)
  + Content of this share :
  ..
- Private Docs - (readable)
  + Content of this share :
  ..
- C$ - (readable,writable)
  + Content of this share :
  bin
  bootmgr
  BOOTMNT
  Documents and Settings
  inetpub
  Oracle
  pagefile.sys
  PerfLogs
```

The right sidebar shows "Plugin Details" for the vulnerability, including fields for Severity, ID, Version, Type, Family, Published, and Modified. The "Risk Information" section shows a "Risk Factor: None".

Vulnerability Assessment x Nessus Essentials / Folders x +

https://academy.hackthebox.com

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec Academy HTB TryHackMe | Dashboard

Target(s): 10.129.202.116 (ACADEMY-VA-SCAN01) Life Left: 109 minute(s) + [Terminate](#)

Authenticate to 10.129.202.116 (ACADEMY-VA-SCAN01) with user "htb-student" and password "htb_academy_student"

What is the name of one of the accessible SMB shares from the authenticated Windows scan? (One word)

Wvus

[Submit](#)

What was the target for the authenticated scan?

172.16.16.100

[Submit](#)

What is the plugin ID of the highest criticality vulnerability for the Windows authenticated scan?

Submit your answer here...

+10 Streak pts [Submit](#)

What is the name of the vulnerability with plugin ID 20925 from the Windows authenticated scan? (Case sensitive)

Submit your answer here...

Screenshot taken

nessus Scans Settings

There's an error with your feed. [Click here to view your license information.](#)

htb-student

Windows_basic_authed / 172.16.16.100

[Back to Hosts](#) [Configure](#) [Audit Trail](#) [Launch](#) [Report](#) [Export](#)

Vulnerabilities 349

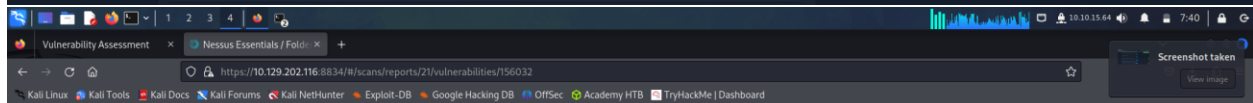
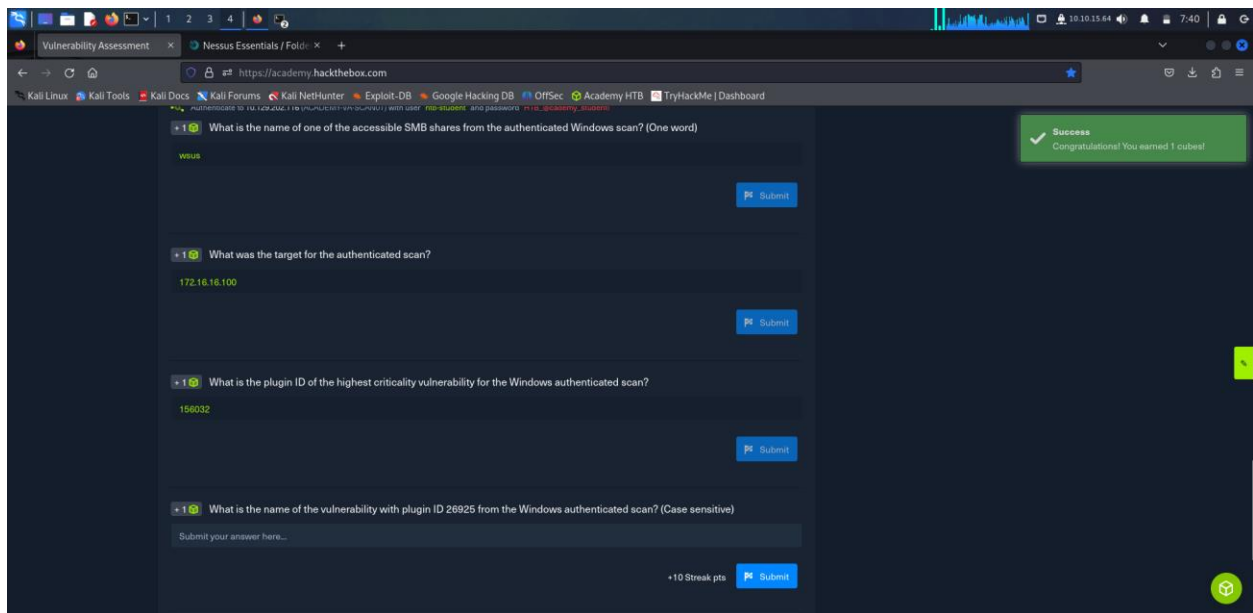
Filter Search Vulnerabilities 349 Vulnerabilities

Sev	Score	Name	Family	Count	
CRITICAL	10.0	Apache Log4j Unsupported Version Detection	Misc.	9	
CRITICAL	10.0	Oracle Java JRE Unsupported Version Detection	Windows	1	
CRITICAL	10.0	Oracle WebLogic Server Multiple Vulnerabilities (April 2017 CPU)	Misc.	1	
CRITICAL	10.0	Oracle WebLogic Server Multiple Vulnerabilities (July 2017 CPU)	Misc.	1	
CRITICAL	10.0	Unsupported Web Server Detection	Web Servers	1	
CRITICAL	9.9	Oracle WebLogic Server Multiple Vulnerabilities (October 2017 CPU)	Misc.	1	
CRITICAL	9.8	Apache Log4j 1.x Multiple Vulnerabilities	Misc.	9	
CRITICAL	9.8	Jenkins LTS < 2.303.3 / Jenkins weekly < 2.319 Multiple Vulnerabilities	CGI abuses	1	
CRITICAL	9.8	KB4022715: Windows 10 Version 1607 and Windows Server 2016 June 2017 Cumulative Update	Windows : Microsoft Bulletins	1	
CRITICAL	9.8	KB4025339: Windows 10 Version 1607 and Windows Server 2016 July 2017 Cumulative Update	Windows : Microsoft Bulletins	1	
CRITICAL	9.8	KB4041691: Windows 10 Version 1607 and Windows Server 2016 October 2017 Cumulative Update (KRACK)	Windows : Microsoft Bulletins	1	

Host Details

IP: 172.16.16.100
MAC: 00:50:56:89:80:5D
OS: Microsoft Windows Server 2016 Standard
Start: 2022-02-12 at 11:54 PM
End: 2022-02-13 at 12:17 AM
Elapsed: 23 minutes
KB: [Download](#)

Vulnerabilities



nessus

Scans Settings

FOLDERS

My Scans

All Scans

Trash

RESOURCES

Policies

Plugin Rules

Windows_basic_authed / Plugin #156032

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 349 Remediations 11 VPR Top Threats History 1

CRITICAL

Apache Log4j Unsupported Version Detection

Description

According to its self-reported version number, the installation of Apache Log4j on the remote host is no longer supported. Log4j reached its end of life prior to 2016.

Lack of support implies that no new security patches for the product will be released by the vendor. As a result, it is likely to contain security vulnerabilities.

Solution

Upgrade to a version of Apache Log4j that is currently supported.

Upgrading to the latest versions for Apache Log4j is highly recommended as intermediate versions / patches have known high severity vulnerabilities and the vendor is updating their advisories often as new research and knowledge about the impact of Log4j is discovered. Refer to <https://logging.apache.org/log4j/2.x/security.html> for the latest versions.

See Also

<http://www.nessus.org/u/59f655a2>

Output

Path : C:\Oracle\Middleware\wlsrver_10.3\samples\server\examples\src\examples\webapp\pubsub\atock\atockEar\APP-INF\lib\log4j-1.2.15.jar

Installed version : 1.2.15

Port Hosts

Plugin Details

Severity: Critical

ID: 156032

Version: 1.2

Type: local

Family: Misc.

Published: December 13, 2021

Modified: December 19, 2021

Risk Information

Risk Factor: Critical

CVSS v3.0 Base Score 10.0

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/AU:N/SC:C/HA:H

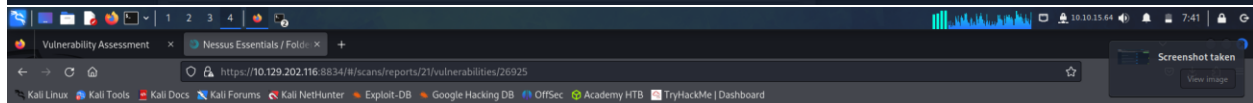
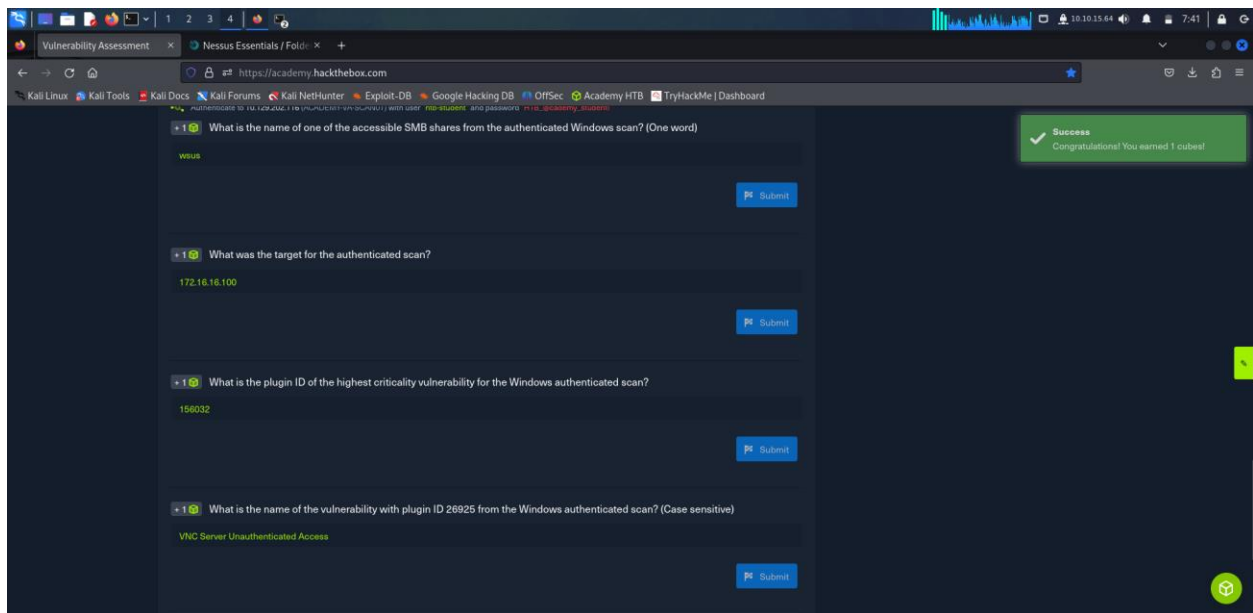
CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

CPE: cpe:/a:apache:log4j

Unsupported by vendor: true



nessus

Scans Settings

There's an error with your feed. Click here to view your license information.

htb-student

Windows_basic_authed / Plugin #26925

Configure Audit Trail Launch Report Export

Hosts 1 Vulnerabilities 1 Remediations 11 VPR Top Threats History 1

HIGH VNC Server Unauthenticated Access

Description

The VNC server installed on the remote host allows an attacker to connect to the remote host as no authentication is required to access this service.

** The VNC server sometimes sends the connected user to the XDM login

** screen. Unfortunately, Nessus cannot identify this situation.

** In such a case, it is not possible to go further without valid

** credentials and this alert may be ignored.

Solution

Disable the No Authentication security type.

Output

No output recorded.

Port	Hosts
5900 /tcp /vnc	172.16.16.100

Plugin Details

Severity: High

ID: 26925

Version: \$Revision: 1.12 \$

Type: remote

Family: Misc.

Published: October 5, 2007

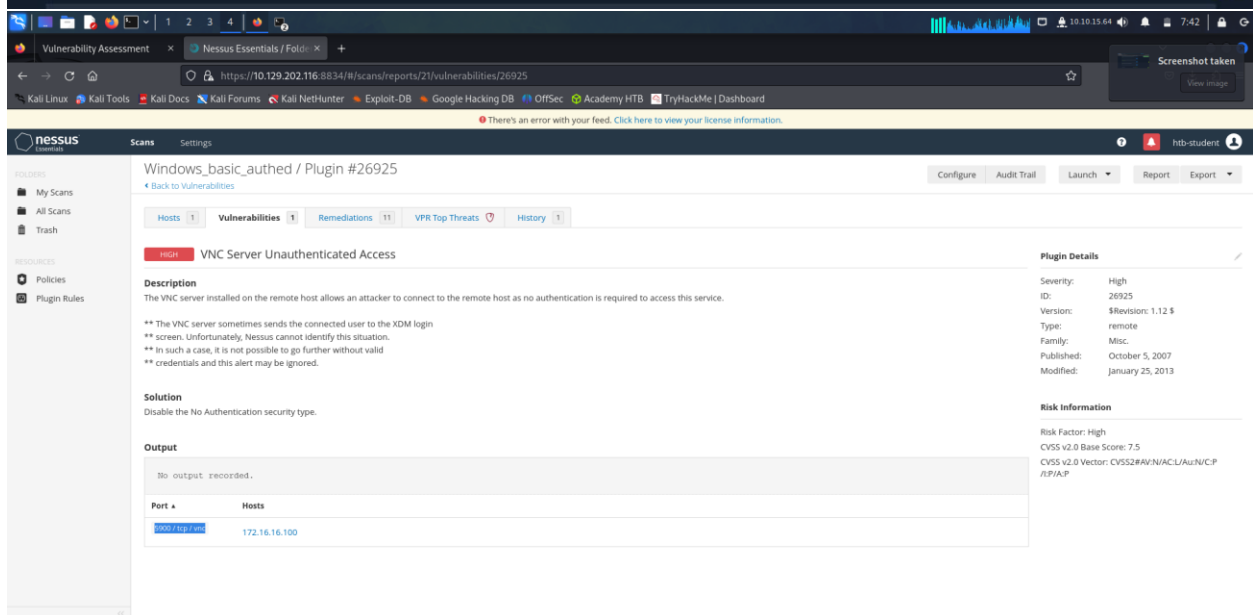
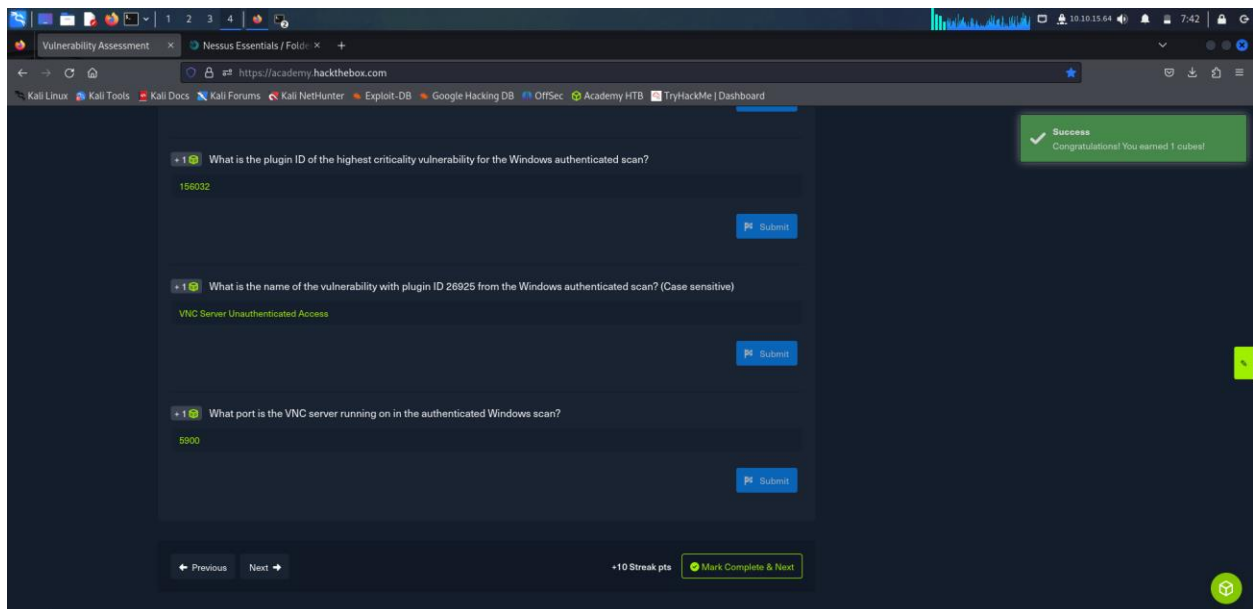
Modified: January 25, 2013

Risk Information

Risk Factor: High

CVSS v2.0 Base Score: 7.5

CVSS v2.0 Vector: CVSS2#AV:N/AC:L/Au:N/C:P/I:P/A:P



Waiting to start...

Success
Congratulations! You earned 1 cubes!

☐ Enable step-by-step solutions for all questions

Questions

Answer the question(s) below to complete this Section and earn cubes!

Download VPN Connection File

Target(s): 10.129.31.251 (ACADEMY-VA-SCAN02)

Life Left: 100 minute(s) Terminate

Authenticate to 10.129.31.251 (ACADEMY-VA-SCAN02) with user "htb-student" and password "HTB_academy_student"

+1 What type of operating system is the Linux host running? (one word)

ubuntu

Submit

+1 What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

Submit your answer here...

+10 Streak pts Submit

+1 What is the IP of the Linux host targeted for the scan?

Submit your answer here...

Report: Sun, Feb 13, 2022 6:04 AM UTC

Greenbone Security Assistant

Filter

Report: Sun, Feb 13, 2022 6:04 AM UTC

Information Results Hosts Ports Applications Operating Systems CVEs Closed CVEs TLS Certificates Error Messages User Tags

Operating System CPE Hosts Severity

Ubuntu 18.04 cpe:/o:canonical:ubuntu_linux:18.04 1 18.0 (info)

Applied filter: apply_overrides=0 levels=host rows=100 min_gid=70 first=1 sort-reverse=severity

Greenbone Security Assistant

Report: Sun, Feb 13, 2022 6:01 AM UTC

ID: 2b466b5-627d-4659-bea6-1758b43235b1 Created: Sun, Feb 13, 2022 1:01 AM UTC Modified: Sun, Feb 13, 2022 1:42 AM UTC Owner: htb-student

Information	Results (4 of 143)	Hosts (12 of 1)	Ports (12 of 6)	Applications (7 of 7)	Operating Systems (12 of 1)	CVEs (12 of 1)	Closed CVEs (0 of 0)	TLS Certificates (0 of 0)	Error Messages (0 of 0)	User Tags (0)
-------------	--------------------	-----------------	-----------------	-----------------------	-----------------------------	----------------	----------------------	---------------------------	-------------------------	---------------

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Report outdated / end-of-life Scan Engine / Environment (local)	99.0 (High)	97 %	172.16.16.160		general/tcp	Sun, Feb 13, 2022 1:03 AM UTC
Anonymous FTP Login Reporting	8.0 (High)	80 %	172.16.16.160		21/tcp	Sun, Feb 13, 2022 1:09 AM UTC
Cleartext Transmission of Sensitive Information via HTTP	8.0 (High)	80 %	172.16.16.160		80/tcp	Sun, Feb 13, 2022 1:21 AM UTC
TCP timestamps	8.0 (High)	80 %	172.16.16.160		general/tcp	Sun, Feb 13, 2022 1:15 AM UTC

(Applied filter: apply_overrides=0 levels=html rows=100 min_god=70 first=1 sort=reverse=severity)

Greenbone Security Assistant (GSA) Copyright (C) 2009-2021 by Greenbone Networks GmbH, www.greenbone.net

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 10.129.31.251 (ACADEMYVA-SCAN02)

Life Left: 107 minute(s) + Terminate X

Authenticate to 10.129.31.251 (ACADEMYVA-SCAN02) with user "htb-student" and password "HTB_academy_student"

1 What type of operating system is the Linux host running? (one word)

ubuntu

Submit

1 What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

Anonymous FTP Login Reporting

Submit

1 What is the IP of the Linux host targeted for the scan?

Submit your answer here...

+10 Streak pts Submit

Success
Congratulations! You earned 1 cubes!

Screenshot taken
View image

Life Left: 107 minute(s) Terminate

Authenticate to 10.129.31.251 (ACADEMY-VA-SCAN02) with user "h1b-student" and password "h1b-academy-student"

What type of operating system is the Linux host running? (one word)

ubuntu

Submit

What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

Anonymous FTP Login Reporting

Submit

What is the IP of the Linux host targeted for the scan?

172.16.16.100

Submit

What vulnerability is associated with the HTTP server? (Case-sensitive)

Submit your answer here...

Submit

Success
Congratulations! You earned 1 cube!

Greenbone Security Assistant

Report: Sun, Feb 13, 2022 6:01 AM UTC

ID: 2b466b5-427d-4659-bea6-1758b43235b1 Created: Sun, Feb 13, 2022 1:01 AM UTC Modified: Sun, Feb 13, 2022 1:42 AM UTC Owner: h1b-student

Information Results Hosts Ports Applications Operating Systems CVEs Closed CVEs TLS Certificates Error Messages User Tags

(4 of 141) (1 of 1) (2 of 6) (7 of 7) (2 of 1) (1 of 1) (0 of 0) (0 of 0) (0 of 0) (0 of 0) (0)

IP Address	Hostname	OS	Ports	Apps	Distance	Auth	Start	End	High	Medium	Low	Log	False Positive	Total	Severity
172.16.16.100			2	7			Sun, Feb 13, 2022 1:03 AM UTC	Sun, Feb 13, 2022 1:42 AM UTC	1	2	1	0	0	4	10.0 (high)

(Applied filter: apply_overrides=0 level=normal rows=100 min_god=70 first=1 sort=reverse=severity)

Greenbone Security Assistant

Information | **Results** (4 of 341) | Hosts (12 of 6) | Ports (17 of 7) | Applications (12 of 1) | Operating Systems (12 of 1) | CVEs (12 of 1) | Closed CVEs (0 of 0) | TLS Certificates (0 of 0) | Error Messages (0 of 0) | User Tags (0)

Vulnerability	Severity	QoD	Host IP	Name	Location	Created
Report outdated / end-of-life Scan Engine / Environment (local)	10.0 (High)	97 %	172.16.16.160		general/tcp	Sun, Feb 13, 2022 1:03 AM UTC
Anonymous FTP Login Reporting	6.4 (Medium)	80 %	172.16.16.160		21/tcp	Sun, Feb 13, 2022 1:09 AM UTC
Outdated Transmission of Sensitive Information via HTTP	6.4 (Medium)	80 %	172.16.16.160		80/tcp	Sun, Feb 13, 2022 1:21 AM UTC

Summary
The host / application transmits sensitive information (username, passwords) in cleartext via HTTP.

Detection Result
The following input fields were identified (URL:input name):
http://172.16.16.160/phpmyadmin/:pma_password
http://172.16.16.160/phpmyadmin/:pma_password

Detection Method
Evaluate previous collected information and check if the host / application is not enforcing the transmission of sensitive data via an encrypted SSL/TLS connection. The script is currently checking the following: - HTTP Basic Authentication (Basic Auth) - HTTP Forms (e.g. Login) with input field of type "password".
Details: [Cleartext Transmission of Sensitive Information via HTTP OID: 1.3.6.1.4.1.25623.1.0.108440](#)
Version used: 2020-08-24T00:00:35Z

Affected Software/OS
Hosts / applications which doesn't enforce the transmission of sensitive data via an encrypted SSL/TLS connection.

Impact

Greenbone Security Assistant (GSA) Copyright (C) 2009-2021 by Greenbone Networks GmbH, www.greenbone.net

What type of FTP vulnerability is on the Linux host? (Case Sensitive, four words)

Anonymous FTP Login Reporting

Submit

What is the IP of the Linux host targeted for the scan?

172.16.16.160

Submit

What vulnerability is associated with the HTTP server? (Case-sensitive)

Cleartext Transmission of Sensitive Information via HTTP

Submit Hint

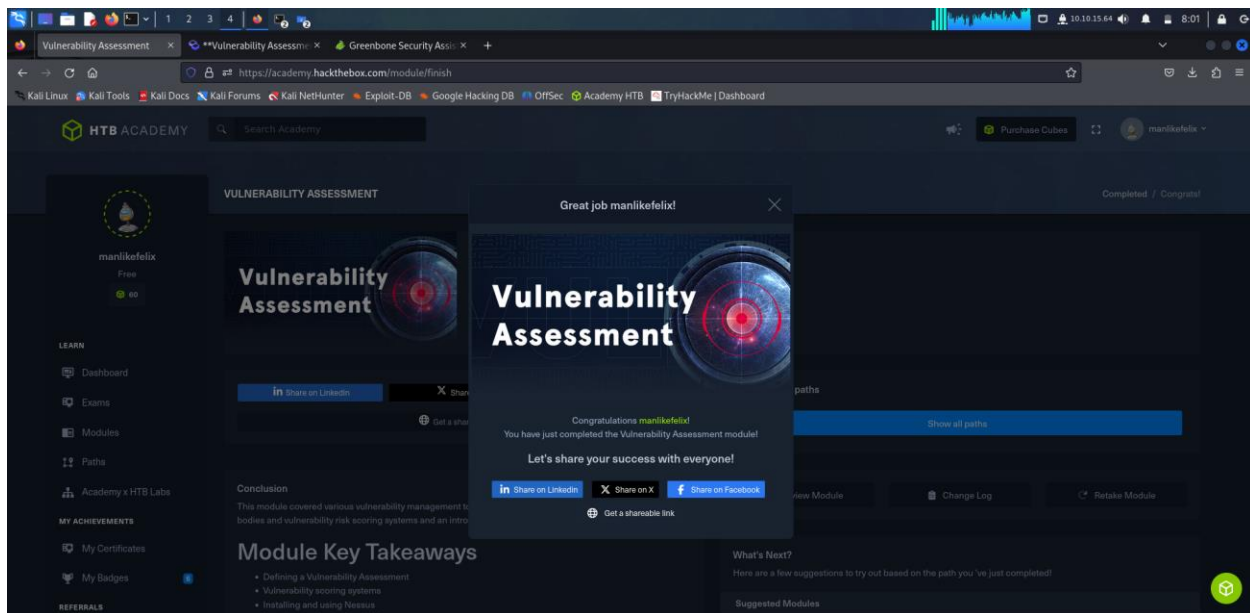
Previous Next

+10 Streak pts Mark Complete & Next

Success
Congratulations! You earned 2 cubes!

3. Shareable Link and Final Screenshot

<https://academy.hackthebox.com/achievement/1919044/108>



4. Social Media Posting

https://www.linkedin.com/uas/login?session_redirect=https%3A%2F%2Fwww.linkedin.com%2FshareArticle%3Furl%3Dhttps%3A%2F%2Facademy.hackthebox.com%2Fachievement%2F1919044%2F108%26title%3DCompleted%2520Vulnerability%2520Assessment!%26summary%3DI%2520just%2520completed%2520the%2520module%2520Vulnerability%2520Assessment%2520in%2520HTB%2520Academy!%23hackthebox%23htbacademy%23cybersecurity&source=HTBAcademy

<https://x.com/intent/tweet?url=https://academy.hackthebox.com/achievement/1919044/108&text=I just completed module Vulnerability Assessment in HTB Academy!&hashtags=hackthebox,htbacademy,cybersecurity>

<https://www.facebook.com/sharer/sharer.php?u=https://academy.hackthebox.com/achievement/1919044/108>

5. Conclusion

Completing this module significantly enhanced my technical proficiency and strategic understanding of vulnerability management. Working with Nessus and OpenVAS provided me with practical experience in configuring, running, and interpreting scans—skills that are directly applicable in real-world cybersecurity roles. I now appreciate the critical role that vulnerability scoring systems play in prioritizing remediation efforts, and how vulnerability assessments differ from penetration testing in both scope and purpose. Additionally, learning to document and report findings effectively has underscored the importance of communication in cybersecurity workflows. This module has strengthened my ability to assess risks, make informed decisions, and contribute meaningfully to an organization's ongoing security operations. I feel more prepared to take on roles that involve identifying and addressing security vulnerabilities in dynamic IT environments.